



UNIVERSIDAD TECNOLÓGICA DE PARRAL



Auditoría Interna de TI'' (DURAPLAY)

P R E S E N T A:

Iker Gerardo Arteaga Huerta
Hiram Yossef Hernández Mendoza
Jesús Ignacio Gutiérrez Sotelo
Juan Adrián Torres Ramos

**DOCENTE: ING. MARÍA DE
LOURDES GARCÍA CARRASCO**

GRUPO: IRIC91V

**CARRERA: ING. EN REDES
INTELIGENTES Y CIBERSEGURIDAD**



1.- RESUMEN EJECUTIVO

La presente auditoría se llevó a cabo con el propósito de evaluar el sistema de videovigilancia de la empresa *DURAPLAY SAPI de CV*, ubicada en Hidalgo del Parral, Chihuahua, México.

Descripción del Alcance

El alcance del estudio abarcó una revisión exhaustiva de los equipos DVR distribuidos en distintas áreas de la instalación, así como un análisis detallado de las condiciones físicas y técnicas de los SITE's donde se alojan estos dispositivos. Además, se verificó la ubicación, funcionalidad y cobertura de las cámaras de seguridad en toda la planta, con el fin de identificar posibles vulnerabilidades que pudieran afectar la eficacia del sistema.

Objetivos de la Auditoría

- Garantizar que el sistema de videovigilancia cumple con los estándares de seguridad y operatividad.
- Detectar fallas técnicas o físicas que puedan comprometer la integridad del sistema.
- Proponer mejoras para optimizar la cobertura y eficiencia de las cámaras.
- Asegurar que los DVR's y los SITE's cumplen con las condiciones adecuadas para su correcto funcionamiento.

Metodología

- 1. Inspección física:** Visita a las instalaciones para evaluar el estado de los equipos y su ubicación.
- 2. Pruebas técnicas:** Verificación del funcionamiento de los DVR's, cámaras y sistemas de almacenamiento.
- 3. Entrevistas:** Conversaciones con el personal responsable del mantenimiento y operación del sistema.
- 4. Análisis documental:** Revisión de manuales, protocolos y registros de mantenimiento previos.

Hallazgos Principales

En la empresa hay 15 DVR distribuidos por cada área de la empresa, encargados de todas las cámaras correspondientes al área. El departamento de sistemas e industrial tienen acceso a los SITE, industrial cuenta con acceso mediante tarjeta por si ocurre una eventualidad.

Recomendaciones Clave

Destacar la implementación de un programa de mantenimiento preventivo regular que incluya limpieza y revisión técnica de los equipos. Se sugiere reubicar aquellas cámaras que no cubran zonas estratégicas, así como actualizar los DVR's obsoletos y mejorar las condiciones de los SITE's para un ambiente óptimo de operación. Finalmente, es fundamental capacitar al personal responsable del sistema, con el fin de optimizar su uso y asegurar una detección temprana de posibles fallas.

2.- DESCRIPCIÓN DE LA EMPRESA Y ALCANCE DE LA AUDITORÍA

Duraplay SAPI de CV

Fabricación de laminados y aglutinados de madera, también se clasifica dentro del sector de materiales para la construcción, ferretería y acabados

Tamaño de la empresa

La empresa Duraplay Emplea más de 250 personas (categoría “251 y más”)

Servicios principales

Tableros de madera:

- Aglomerado (MDP)
- MDF (Fibraplay)
- Triplay

Tableros recubiertos:

- Melamina (Duramel Sense)
- Enchapado (Duracore)
- Foil (Duralam)
- Ranurados (Dupanel)

Justificación del área

Realizar la auditoría del sistema de cámaras bajo el enfoque de la norma ISO 27001 permite asegurar que los datos captados por las cámaras de

seguridad, que suelen ser información sensible y altamente privada de la empresa, por esta razón, se debe asegurar que estén protegidos adecuadamente frente a amenazas que puedan afectar su confidencialidad, integridad y disponibilidad.

Alcance de la auditoría

El área a revisar es el sistema de videovigilancia instalado en las instalaciones principales de la empresa Duraplay. Se revisará la infraestructura observable del sistema, incluyendo la ubicación de cámaras, la cobertura visual y las prácticas básicas de resguardo de grabaciones.

La importancia del sistema de cámaras ayuda a la prevención de riesgos como accesos no autorizados, pérdidas materiales y trazabilidad de incidentes. Por estas razones, dicho sistema puede registrar datos sensibles o personales, por lo que representa un activo de información cuyo tratamiento debe estar alineado con principios de confidencialidad, integridad y disponibilidad.

3.- MARCO NORMATIVO APLICADO

Normas aplicadas

La auditoría se basará en la norma internacional ISO 27001, que establece los requisitos para implementar, mantener y mejorar un Sistema de Gestión de Seguridad de la Información (SGSI). Esta norma permite identificar riesgos asociados al tratamiento de la información y definir controles para proteger su confidencialidad, integridad y disponibilidad.

Sistema de Gestión de Seguridad de la Información (SGSI):

Se evaluará si el sistema de videovigilancia está formalmente incluido dentro del SGSI, con políticas, procedimientos y responsabilidades claramente definidos.

Gestión de riesgos de seguridad de la información:

Se revisará si se han identificado y tratado los riesgos específicos relacionados con el uso, almacenamiento y acceso a las grabaciones.

Controles físicos, técnicos y organizacionales:

Se analizará la existencia de medidas que protejan el acceso a las cámaras, servidores, estaciones de monitoreo y grabaciones.

Cumplimiento legal y regulatorio:

Se verificará el cumplimiento con las normativas sobre videovigilancia, protección de datos personales y privacidad, en línea con el dominio A.18 de la norma.

A.18 - Alineación con leyes de protección de datos personales y videovigilancia.

Criterios utilizados para la auditoría.

Durante la auditoría se utilizó un cuestionario para recabar información.

1. Control de accesos

- ¿Quién tiene acceso físico a las grabaciones?
- ¿Quién puede acceder al sistema de videovigilancia (servidores, DVRs, NVRs)?

- ¿Las contraseñas por defecto han sido cambiadas?
- ¿Se usan cuentas individuales y seguras?

2. Seguridad física y ambiental

- ¿Dónde están ubicados los servidores de grabación o almacenamiento?
- ¿Están en lugares seguros, con acceso controlado?
- ¿Hay protección contra daños físicos (temperatura, humedad, etc.)?

3. Seguridad de las comunicaciones

- ¿Las cámaras están conectadas a la red de forma segura?
- ¿Se cifran las transmisiones de video (especialmente si son IP)?
- ¿Hay segmentación de red o VLANs para aislar el sistema de cámaras?

4. Gestión de activos

- ¿Las cámaras y los equipos de videovigilancia están inventariados?
- ¿Se protege adecuadamente la información que generan?

5. Gestión de incidentes de seguridad

- ¿Qué sucede si se detecta un intento de acceso no autorizado al sistema de cámaras?
- ¿Existe un procedimiento de respuesta ante incidentes?
- ¿Se documentan estos incidentes?

6. Políticas de seguridad de la información

- ¿La empresa tiene políticas específicas sobre el uso, resguardo y revisión de las grabaciones?
- ¿Se informa al personal sobre las políticas?

7. Cumplimiento legal

- ¿Se informa al público o empleados sobre el uso de cámaras, como exige la ley?
- ¿Hay letreros visibles que indiquen la presencia de videovigilancia?

8. Control de configuración y mantenimiento

- ¿Los equipos (cámaras, routers, grabadoras) están actualizados?
- ¿Se realiza mantenimiento preventivo y correctivo?
- ¿Se revisa periódicamente la configuración de seguridad?

9. Retención y borrado de grabaciones

- ¿Cuánto tiempo se almacenan las grabaciones?
- ¿Existe un proceso seguro para eliminar grabaciones antiguas?
- ¿Se limita el acceso a esas grabaciones durante su retención?

4.- DIAGNÓSTICO INICIAL CON CHECKLIST

En el caso de Duraplay S.A.P.I. de C.V., la herramienta de checklist permite llevar a cabo una inspección detallada del sistema de videovigilancia implementado en sus instalaciones industriales y zonas de producción. Este instrumento permite estandarizar la recolección de evidencias, identificar fallos en el sistema y asegurar que los dispositivos de monitoreo estén alineados con los controles de seguridad exigidos por la norma ISO 27001 y las políticas internas de Duraplay.

Pregunta	Si	No	Observaciones
¿Quién tiene acceso físico a las grabaciones está claramente definido y restringido?	x		El departamento de sistemas, así como el departamento de industrial tienen acceso a los site. Industrial cuenta con acceso mediante tarjeta por si ocurre una eventualidad.
¿Está controlado quién accede al sistema de videovigilancia (servidores, DVRs, NVRs)?	x		Hay 2 usuarios, uno para monitorear y otro para poder verificar grabaciones.
¿Se cambiaron las contraseñas por defecto en todos los dispositivos?	x		
¿Se usan cuentas individuales, con contraseñas seguras y sin compartir credenciales?		x	
¿Los servidores de grabación o almacenamiento están ubicados en un lugar seguro?	x		
¿El acceso físico a estos equipos está controlado (candados, tarjetas, biometría)?	x		El site de sistemas cuenta con lector de huellas dactilares.
¿Existe protección contra riesgos ambientales (temperatura, humedad, incendio)?	x		El site principal cuenta con un detector de humedad y temperatura que manda notificaciones.
¿Las cámaras están conectadas a la red mediante medios seguros?	x		
¿Se cifra la transmisión de video, especialmente en cámaras IP?	x		
¿Se implementa segmentación de red o VLANs para aislar el sistema de cámaras?	x		
¿Las cámaras y equipos de videovigilancia están inventariados?	x		
¿La información generada por el sistema está protegida adecuadamente?	x		
¿Se detectan e investigan intentos de acceso no autorizado al sistema de cámaras?	x		
¿Existe un procedimiento de respuesta a incidentes para este sistema?	x		Si se detecta un intento de acceso no autorizado al sistema de cámaras se avisa a su superior, de ahí se pasa la información a sistemas para verificar quien fue el intruso para tomar medidas.

¿Los incidentes detectados se documentan y analizan?	x		
¿La empresa tiene políticas específicas sobre el uso, resguardo y revisión de grabaciones?	x		
¿El personal conoce dichas políticas?	x		
¿Se informa a empleados y visitantes sobre el uso de videovigilancia?	x		
¿Existen letreros visibles que indiquen la presencia de cámaras?	x		En la entrada están los letreros correspondientes
¿Los equipos (cámaras, grabadores, routers) tienen firmware actualizado?	x		
¿Se realiza mantenimiento preventivo y correctivo regularmente?		x	Se realiza cada 6 meses por un proveedor.
¿Se revisa periódicamente la configuración de seguridad del sistema?		x	
¿Existe un periodo definido para la retención de grabaciones?	x		El periodo es de 30 días
¿Se siguen procesos seguros para la eliminación de grabaciones antiguas?		x	Se limpian solos, cada determinado tiempo.
¿El acceso a grabaciones en retención está restringido y controlado?	x		

5.- ANÁLISIS DE RIESGOS

Tabla de riesgos identificados

ID	Riesgo Identificado	Probabilidad	Impacto	Nivel de Riesgo
R1	Fallo en DVRs por falta de mantenimiento preventivo	Alta	Alta	Crítico
R2	Ubicación inadecuada de cámaras (zonas ciegas o ángulos muertos)	Media	Alta	Alto

R3	Condiciones inadecuadas de los SITE's (temperatura, humedad, ventilación)	Alta	Alta	Crítico
R4	Acceso no autorizado a los DVRs o salas de SITE	Media	Alta	Alto
R5	Pérdida de grabaciones por ausencia de respaldo automático	Alta	Alta	Crítico
R6	Vulnerabilidad en DVRs por contraseñas débiles o no cambiadas desde fábrica	Alta	Alta	Crítico
R7	Corte de energía eléctrica sin respaldo (UPS o planta)	Media	Alta	Alto
R8	Daños en cámaras por exposición a polvo, humedad o golpes	Media	Media	Medio
R9	Cableado deteriorado o mal organizado en racks/SITE	Alta	Media	Alto
R10	Falta de monitoreo en tiempo real de las grabaciones	Media	Alta	Alto

Medidas de Mitigación (ISO 27001)

A.9 – Control de Acceso:

- Establecer contraseñas robustas en todos los DVRs y cambiarlas periódicamente.

- Implementar control de acceso físico a los SITE's con cerraduras, biometría o tarjetas de proximidad.

A.11 – Seguridad Física y del Entorno:

- Mantener los SITE's en condiciones óptimas (aire acondicionado, ventilación, control de humedad).
- Instalar UPS en cada SITE para asegurar funcionamiento en cortes eléctricos.

Señalización de áreas restringidas y cámaras críticas.

A.12 – Operación Segura:

- Realizar respaldos automáticos de grabaciones en servidores seguros o almacenamiento en la nube.
- Definir procedimientos de mantenimiento preventivo y correctivo de cámaras y DVRs.

A.13 – Seguridad en Comunicaciones:

- Revisar cableado estructurado, eliminando improvisaciones y garantizando canalizaciones seguras.
- Cifrar la transmisión de video en caso de acceso remoto a DVRs.

A.16 – Gestión de Incidentes de Seguridad:

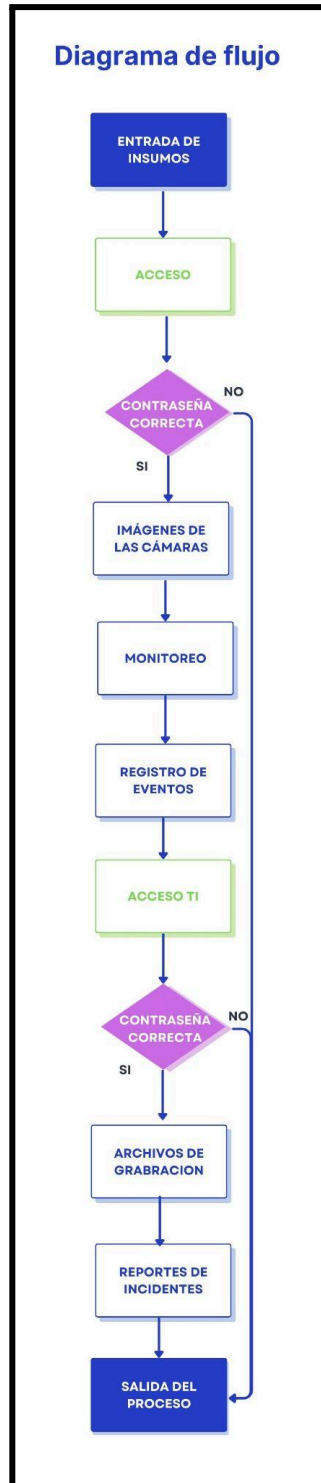
- Establecer un protocolo de respuesta en caso de pérdida de grabaciones o accesos no autorizados.

- Registro de incidentes detectados y acciones correctivas.

A.17 – Continuidad del Negocio:

- Plan de recuperación en caso de fallas críticas de DVRs.
- Redundancia de grabaciones en más de un dispositivo.

6.- MAPA DE PROCESOS Y DIAGRAMA DE FLUJO DEL ÁREA AUDITADA



7.- PROPUESTA DE INDICADORES CLAVE (KPIs)

1. Porcentaje de cámaras operativas respecto al total instalado

Indicador de mantenimiento y funcionalidad del sistema.- Se refiere al número de cámaras que se encuentran en perfecto estado de funcionamiento (grabando, transmitiendo y con todos sus componentes activos) en relación con el total de cámaras instaladas, sean estas operativas o no.

2. Tiempo promedio de respuesta ante incidentes detectados

Mide la eficiencia del personal en situaciones críticas.- Representa el lapso promedio, medido en minutos u horas, desde el momento en que un incidente es identificado a través del sistema de cámaras hasta que se inicia la acción correctiva o de verificación por parte del personal de seguridad o monitoreo.

3. Número de incidentes registrados por turno

Permite identificar patrones por horario o deficiencias en la vigilancia.-

Cuantifica la cantidad de eventos anómalos o de seguridad (robos, accesos no autorizados, fallas de equipo, comportamientos sospechosos, etc.) que son detectados y registrados por el personal o el sistema de monitoreo durante cada turno de trabajo establecido.

4. Nivel de cumplimiento del protocolo de monitoreo (%)

Evalúa si los procedimientos internos se están aplicando correctamente.- Mide el porcentaje de adherencia del personal de monitoreo y seguridad a los pasos y directrices preestablecidos en el protocolo de operación del sistema de cámaras, incluyendo rondas de vigilancia, registro de eventos, y procedimientos de respuesta.

5. Porcentaje de grabaciones respaldadas correctamente

Indica la integridad de la evidencia generada.- Se refiere a la proporción de grabaciones de seguridad que han sido almacenadas, copiadas o archivadas de acuerdo con la política de retención y los procedimientos establecidos, asegurando su disponibilidad y autenticidad en caso de ser requeridas como evidencia.

6. Satisfacción de las áreas usuarias respecto al soporte brindado

Refleja la percepción de eficacia del centro de monitoreo.- Evalúa, a través de encuestas o retroalimentación directa, el grado de conformidad de los departamentos o usuarios internos (producción, administración, etc.) con la calidad, rapidez y utilidad del soporte y la información proporcionada por el centro de monitoreo de cámaras.

Definición de KPIs para evaluar la efectividad de la auditoría:

Tasa de cumplimiento de controles (ISO 27001):

- **Definición:** Porcentaje de controles de seguridad implementados y verificados frente al total de controles aplicables revisados en la auditoría.

Justificación: Permite medir de forma objetiva la efectividad de la auditoría en términos de seguridad y normatividad.

Índice de hallazgos críticos detectados:

- **Definición:** Número de hallazgos clasificados como “críticos” en proporción al total de hallazgos identificados.
- **Justificación:** Aporta visibilidad sobre la gravedad de las vulnerabilidades encontradas, lo que orienta la priorización de acciones correctivas.

Tiempo promedio de implementación de acciones correctivas:

- **Definición:** Lapso (en días) entre la notificación de un hallazgo y la aplicación de la medida correctiva correspondiente.

- **Justificación:** Permite evaluar la capacidad de respuesta y la eficiencia del plan de mejora continua.

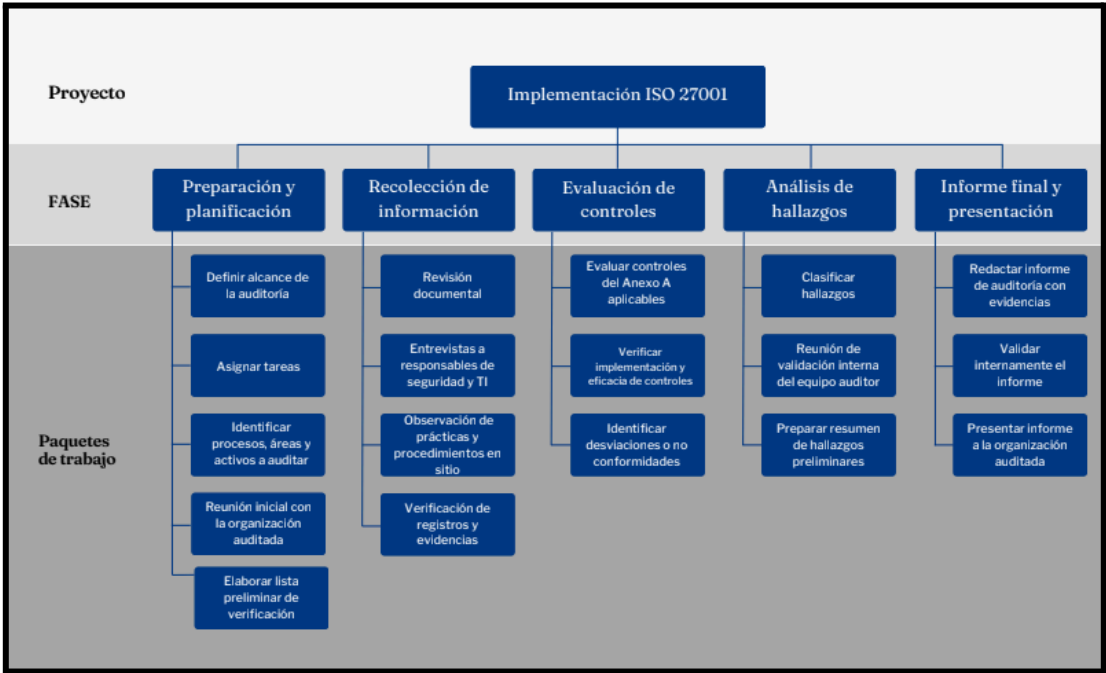
Porcentaje de cámaras cubiertas bajo mantenimiento preventivo:

- **Definición:** Proporción de cámaras y DVRs que han recibido mantenimiento preventivo frente al total instalado.
- **Justificación:** Refleja el compromiso con la prevención de fallas y la continuidad del sistema.

Nivel de satisfacción del personal con las mejoras implementadas:

- **Definición:** Promedio de calificación obtenida en encuestas internas al personal de TI y usuarios del sistema de videovigilancia.
- **Justificación:** Mide el impacto de las acciones de mejora en la percepción de quienes operan el sistema día a día.

8.- PLANIFICACIÓN Y CRONOGRAMA DE LA AUDITORÍA



Cronograma Auditoria

[illegible]

9.- ESTIMACIÓN DE COSTOS Y RECURSOS

Rubro	Costo Estimado
Recursos Humanos	\$25,200
Recursos tecnológicos \$520	
Software de análisis de red (Wireshark, gratuito)	\$0
Licencia básica de software de gestión de auditorías AuditBoard	\$150
Laptop con capacidad de análisis (ya disponible)	\$0
Cámara IP portátil para pruebas (1 unidad)	\$290
Dispositivo de prueba PoE	\$80
Otros gastos \$3,350	
Transporte	\$3,350 por 5 días
Papelería	\$50
TOTAL	\$29,070

10.- ANÁLISIS DE HALLAZGOS Y RECOMENDACIONES

Durante la auditoría al sistema de videovigilancia de Duraplay S.A.P.I. de C.V., se identificaron los siguientes hallazgos principales, los cuales representan riesgos de seguridad y disponibilidad de la información. A cada hallazgo se le asocian recomendaciones concretas para mejorar la seguridad y alinearse con la norma ISO 27001.

Hallazgos Identificados:

- Solo el SITE principal cuenta con sensor de humedad y humo; los otros dos carecen de este tipo de protección.
- Esto expone a los equipos a riesgos de daños físicos por IDF en malas condiciones
- Durante la inspección física se observó que algunos IDF tenían objetos encima de los racks, lo que no solo compromete la ventilación y el orden del cableado, sino que también representa un riesgo físico de daño accidental. Además, se detectó que uno de los IDF dejó de funcionar debido a la filtración de agua.
- En el SITE de Farmoquimia se reportó la caída de un plafón a causa de filtraciones de agua, lo que ensució y afectó el equipo instalado en la zona. Este hecho pone en riesgo la operatividad del sistema de videovigilancia.

Recomendaciones

- Instalar sensores de humedad, humo y temperatura en todos los SITE e IDF.

- Implementar medidas correctivas inmediatas para evitar filtraciones de agua en áreas críticas.
- Mantener los racks libres de objetos encima, garantizando ventilación adecuada y evitando sobrepeso.
- Realizar una reubicación o reacondicionamiento del IDF dañado para asegurar su operación.
- Asegurar limpieza en el SITE de Formoquimia.

Evidencias



Site con sensor



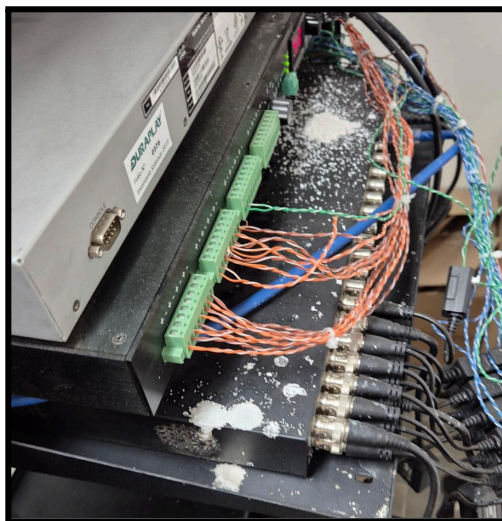
IDF con objetos encima



IDF que tuvo filtrado de agua



Daños del plafón 1



Daños del plafón 2

11.- PLAN DE COMUNICACIÓN Y MATRIZ DE COMUNICACIÓN

Objetivos de la comunicación: - Informar de manera clara los hallazgos y riesgos detectados. - Persuadir a la dirección de la urgencia de implementar medidas. - Coordinar las acciones de mejora con el equipo de TI y proveedores.

Audiencia objetivo: - Directivos - Equipo de TI - Proveedores de servicios TI - Clientes (comunicación preventiva si se comprometió información) - Auditores externos o de cumplimiento

Canales sugeridos: - Reuniones presenciales o virtuales - Correos electrónicos con resumen ejecutivo - Reportes técnicos detallados - Presentaciones visuales para comités

Frecuencia y responsables: - Comunicación inicial inmediata post-auditoría (Responsable: Auditor Líder) - Seguimiento semanal de acciones correctivas (Responsable: Jefe de TI) - Informe final al mes (Responsable: Coordinador de cumplimiento)

Mensajes clave: - Para directivos: “Existe un riesgo crítico por contraseñas vulnerables que requiere acción urgente.” - Para equipo TI: “Se deben cambiar todas las contraseñas default y aplicar mejores prácticas de seguridad.” - Para proveedores: “Se exige cumplimiento de políticas seguras en los equipos y servicios suministrados.”

Matriz de Comunicación

Audiencia	Información a comunicar	Canal	Frecuencia	Responsable	Formato
Directivos	Riesgos, hallazgos y plan de acción	Reunión + email ejecutivo	Inicial + mensual	Auditor líder	Presentación PDF
Equipo TI	Detalles técnicos y tareas correctivas	Reunión + reporte interno	Semanal	Jefe de TI	Informe técnico DOCX
Proveedores TI	Requerimientos de seguridad en sus productos/servicios	Email formal + checklist	Unica o por contrato	Coordinador de compras	Checklist y oficio PDF
Clientes (si aplica)	Garantía de acciones para proteger sus datos	Email institucion al	Solo si es necesario	Gerente de comunicación	Comunicado institucion al

Auditores externos	Resultados de auditoría y seguimiento de hallazgos	Reporte formal	Al cierre	Auditor líder	Informe firmado PDF
-------------------------------	---	-------------------	-----------	---------------	---------------------------

12.- CONCLUSIONES FINALES

Esta auditoría al sistema de videovigilancia de DURAPLAY ha demostrado la importancia crítica de mantener controles robustos en seguridad física y digital. Los hallazgos revelaron vulnerabilidades significativas, particularmente en gestión de accesos, protección de datos y continuidad operativa, que de no atenderse podrían comprometer la integridad del sistema.

Las recomendaciones planteadas, aunque requieren inversión, son técnica y financieramente viables, ofreciendo beneficios inmediatos como mayor protección contra amenazas y cumplimiento normativo. Su implementación escalonada permitirá optimizar recursos mientras se fortalecen progresivamente los controles.

El principal aprendizaje radica en que la seguridad efectiva exige un enfoque integral - combinando tecnología, procesos y capacitación. Esta auditoría no solo identificó gaps, sino que estableció una hoja de ruta clara para transformar el sistema de videovigilancia en un activo estratégico confiable. La empresa cuenta ahora con los insumos necesarios para tomar decisiones informadas que eleven sus estándares de protección.

Se recomienda iniciar con acciones prioritarias como la actualización de credenciales y firmware, asignando responsables para dar seguimiento al plan de mejora continua. Con compromiso sostenido, DURAPLAY podrá asegurar no solo sus instalaciones físicas sino también su información crítica.

13.- ANEXOS

MATRIZ RACI

R = Responsable (quien ejecuta la tarea)

A = Aprobador o Autoridad final (quien toma la decisión o valida)

C = Consultado (quien aporta información o participa)

I = Informado (quien debe estar enterado – no se usó aquí porque es un equipo pequeño)

Actividad	Auditoría ISO 27001 al Sistema DURAPLAY			
	Hiram	Jesús	Iker	Juan
Levantamiento de información	A	R	R	C
Análisis de riesgos	A	A	R	C
¿Revisión de políticas y procedimientos de seguridad	R	C	A	A
Evaluar controles de acceso al sistema	C	R	A	R
Informe de hallazgos	A	A	C	R
Preparación de resultados	R	R	A	C
Presentación de resultados	R	A	A	A